



المؤسسة العامة للتدريب التقني والمهني
Technical and Vocational Training Corporation



معهد التميز الأمريكي للتدريب
American Excellence Higher Training
Institute

الحماية من الجرائم الإلكترونية

دراسة تأصيلية وتطبيقية لتطوير منصة تفاعلية متكاملة للتقييم الأمني والتوعية السيبرانية الذكية



CyberShield Platform



إعداد الطالبات:

رؤى عبدالله
غالية محمد
ريم كليبي
لولوه فهد
روابي موسى
حسناء أحمد

إشراف المدربة القديرة:

الأستاذة / عفاف أحمد

العام الجامعي:

1448 هـ - 1449 هـ

فجوة الوعي واستغلال العنصر البشري: مشكلة البحث

⚠️ الحقيقة السيبرانية: الإنسان هو خط الدفاع الأول والأكثر استهدافاً

تؤكد التقارير الأمنية الدولية (Verizon & NIST) أن أكثر من 85% من الاختراقات الناجحة ترجع إلى استغلال الثغرات السلوكية عبر الهندسة الاجتماعية والتصيد، وليس إلى كسر الخوارزميات المشفرة.

❌ أسلوب التوعية التقليدي (الوضع الراهن)

- قوالب نظرية ساكنة: مطويات ومحاضرات تلقينية جامدة.
- انعدام الممارسة: غياب بيئات محاكاة آمنة لاختبار رد الفعل.
- لا يوجد قياس حقيقي: الاعتماد على تخمين المستخدم لوعيه.
- النتيجة: الوقوع السريع ضحية للهندسة الاجتماعية عند الهجوم الفعلي.

✓ نموذج CyberShield التفاعلي (الحل المبتكر)

- تعلم تجريبي حي: مواقف تفاعلية متدرجة الخطوات.
- بيئة آمنة ومعزولة: (Sandbox) محاكاة الهجوم دون مخاطرة.
- قياس موضوعي مقنن: تشخيص قبلي ومقارنة بعدية دقيقة.
- فحص ذاتي محلي: أدوات فحص استدلالي تكشف خداع الروابط والرسائل.

أهداف المشروع والركائز الأربع للحل التفاعلي

الهدف العام للمشروع:

تطوير منصة ويب تفاعلية ذكية ومتكاملة تساهم في تشخيص ورفع الوعي الأمني للمستخدمين وحمايتهم من الجرائم الإلكترونية عبر مسار مقنن، وسيناريوهات محاكاة واقعية، وأدوات فحص أمنة ومحلية.

1. المسار المقنن (7 Modules)

تغطية 7 وحدات تعليمية تفاعلية تمثل الركائز الحيوية للسلامة الرقمية اليومية.

2. التشخيص الدقيق (Pre-Assessment)

قياس المستوى الأمني الأولي لتحديد خط الأساس المعرفي وتحديد مكانم الضعف.

3. التحليل الذاتي (Safe Analyzer)

توفير أدوات فحص استدلالي محلي للروابط والرسائل المشبوهة وتفكيك النطاقات دون خطر.

4. محاكاة المواقف (Scenarios)

محاكاة مواقف واقعية متعددة الخطوات تتيح للمستخدم اتخاذ القرارات واستلام تغذية فورية.

من المدخلات إلى المخرجات الذكية: إنفوجرافيك تدفق العمليات

المرحلة 1: المدخلات (Inputs)

- إجابات التقييم القبلي والبعدي.
- نصوص الرسائل والروابط المشبوهة.
- قرارات واستجابات محاكي السيناريو.
- محتوى الدروس والاختبارات للمدرس.

المرحلة 2: المعالجة الآمنة (Processing)

- التحقق الصارم من الصلاحيات (RBAC).
- محرك الفحص الاستدلالي المحلي للروابط.
- خوارزميات تحليل نقاط الضعف السلوكية.
- إنفاذ حماية الملكية ومنع ثغرات IDOR.

المرحلة 3: المخرجات الذكية (Outputs)

- مؤشر وعي تراكمي وتحديد نسبة الإتقان.
- خطة علاجية وتوصيات وقائية مخصصة.
- تغذية راجعة مشروحة لخيارات المتدرب.
- لوحات تحكم وسجلات تدقيق أمني للمشرف.

المعمارية البرمجية ومنظومة التقنيات المستخدمة فعلياً

طبقة الواجهة الأمامية (Frontend)

React 19: بناء واجهة تفاعلية سلسلة وقائمة على المكونات (Component-Based).
TypeScript: ضمان التوافق البرمجي ومنع الأخطاء النوعية (Type-Safety).
Tailwind CSS: تصميم عصري باللغة العربية يدعم RTL بدقة وهدوء بصري مريح.
Lucide React: أيقونات أمنية متناسقة ومؤشرات بصرية واضحة.

طبقة الخادم والاتصال (Backend & API)

Node.js & Express: بيئة تشغيل سريعة وموثوقة لمعالجة الطلبات.
tRPC Framework: بناء واجهات اتصال متزامنة وأمنة تماماً تلغي الفجوة بين العميل والخادم وتمنع تسريب الإجابات عبر الشبكة.
Jose (JWT): إدارة رموز الجلسات والمصادقة الأمنية المشفرة.

طبقة البيانات والحفظ (Database & ORM)

Better-SQLite3: محرك قواعد بيانات محلي مدمج عالي السرعة والأداء.
Drizzle ORM: معالج الكائنات المترابطة مع استعلامات معيارية parameterized توفر حماية مدمجة ضد هجمات حقن قواعد البيانات (SQL Injection).
تصميم علائقي للجداول: المستخدمين، الدروس، الأسئلة، والسيناريوهات.

طبقة الأمان وضمان الجودة (Security & QA)

Bcrypt.js: تشفير وتمليح كلمات المرور عشوائياً (Salt Rounds).
Rate Limiter: كبح هجمات القوة الغاشمة ومحاولات التخمين.
Strict CSP: سياسة أمان محتوى صارمة تمنع ثغرات XSS.
Vitest: حزمة الاختبارات الآلية الشاملة (157/157) اختباراً ناجحاً بنسبة 100%.

مسار التوعية التفاعلي والوحدات السبع المعتمدة

مرحباً بك (متصفح)

مسعود العتيبي - تجربة مستخدم

مهمة CyberShield Awareness للأمنية

رحلك نحو وعي رقمي وأمان سيبراني أقوى

المناهج التدريسية للأمنية > 7 وحدات متوفرة

مسار التوعية والتعلم السيبراني

رحلة تدريبية متكاملة تبدأ باكتشاف أساليب التصيد وتنتهي ببروتوكولات الاستجابة السريعة للحوادث.

7
دروس متاحة

0%
نسبة الإكمال

0 مؤشر التقدم في المسار التوعوي من 7 دروس مكتملة

ابدأ بإعادة الدرس الأول حيثما أحسب نفسك في المهمة

▼ تصفية التصنيفات:

جميع الوحدات (7)
أمان الحسابات وكلمات المرور
التصديق الآمن وتحليل الروابط
التصيد والهندسة الاجتماعية
الملفات والبرمجيات الخبيثة
حماية الأجهزة والبيانات

حماية الحسابات وكلمات المرور
تحقق الروابط والنطاقات

7 > غير مكتمل
3 دروس

حماية الحسابات والمصادقة متعددة العوامل (MFA)

Account Protection & Multi-Factor Authentication

لماذا تعد كلمات المرور وحدها غير كافية؟ وكيف توفر تطبيقات المصادقة ثباتاً محبباً حتى في حال سرقة كلمة المرور؟

اختر الدرس
⌵

الهيئة التدريبية
⌵

قراءة الدرس <
اختيار الدرس ⌵

5 > غير مكتمل
2 دروس

اقرأ الرابط قبل أن تنقر: التحليل التريكي للروابط

Read Before You Click: Safe Link Inspection

فهم أجزاء الرابط البروتوكول، النطاق الأساسي، النسخ الفرعي، وكيف تفسر الوجهة الحقيقية قبل دمجها.

اختر الدرس
⌵

الهيئة التدريبية
⌵

قراءة الدرس <
اختيار الدرس ⌵

6 > غير مكتمل
1 درس

كيف تتكشف رسائل التصيد والاحتيال؟

How to Detect Phishing Messages

تعمّق قراءة الرسائل غير المعتادة وكشف أساليب الضغط والاستغلال وتحليل الهوية المزعومة.

اختر الدرس
⌵

الهيئة التدريبية
⌵

قراءة الدرس <
اختيار الدرس ⌵

🔒 تم تسجيل تفهيمك الأولي وتمتعت برصيد الوعي الهيكلي بنجاح!

شمولية التغطية التوعوية (الوحدات السبع):

1. الهندسة الاجتماعية: أساليب التلاعب النفسي والتصيد.
2. كلمات المرور: قواعد التعقيد وإدارة المفاتيح والتحقق 2FA.
3. البرمجيات الخبيثة: برامج الفدية، التروجان، وطرق الوقاية.
4. أمن الشبكات والتصفح: شهادات SSL ومخاطر Wi-Fi العامة.
5. حماية الخصوصية: تقليل البصمة الرقمية ومكافحة التتبع.
6. الاحتيال المالي: حيل البطاقات والمتاجر الإلكترونية الوهمية.
7. الاستجابة للحوادث: خطوات التصرف الفوري والإبلاغ المعتمد.

🔒 **ميزة الأمان:** الدروس السبعة الرسمية محصنة برمجياً ومحمية من التعديل أو الحذف من أي مستخدم.

شكل (1): واجهة استعراض مسار التوعية والوحدات السبع المعتمدة

بنك الاختبارات والنزاهة الأمنية للتقييم (Quizzes)

مهمة CyberShield Awareness التأسيسية
رحلتك نحو وعي رقمي وأمان سيبراني أقوى

درع الوعي السيبراني
CyberShield Platform

مساحتك الشخصية
نظرة عامة
المطل الأمن
مسار التوعية

أختبر نفسك

تأكيد الأمان
التحليل محلي وتطبيقات عالمي الأمن من زوايا
مختلفة

مرحباً بك (مختبر)
سعود العتيبي - تجربة مستخدم

الوحدة 1 من 7

العودة لمركز الاختبارات

السؤال 1 من 5
نسبة الإجابة: 20%

اختبار الوحدة 1: كشف رسائل التصيد والاحتيال

وصلتك رسالة نصية عاجلة تزعم أن حسابك البنكي سيتوقف خلال ساعتين وتطلب إدخال رمز التحقق OTP المرسل لهاتفك في رابط مرفق. ما هو التصرف الأمني الصحيح؟

1 إدخال الرمز فوراً لتجنب حظر الحساب

2 إرسال الرسالة إلى الأصدقاء لمعرفة ما إذا وصلهم نفس الشيء

3 تجاهل الرابط والاتصال فوراً بالبنك عبر رقمه الرسمي المخصص للتأكد

4 الرد على الرسالة بكلمة "إلغاء"

السؤال التالي >

إلغاء الوحدة

شكل (2): واجهة خوض الاختبارات التفاعلية وفحص الاستيعاب

معايير النزاهة والأمان في الاختبارات:

حظر تسريب الإجابات عبر الشبكة:

ترسل واجهة tRPC الأسئلة والخيارات مجردة تماماً من حقل الإجابة الصحيحة (isCorrect)، مما يمنع استخراجها عبر أدوات فحص المتصفح. (F12).

التصحيح الحصري على الخادم:

يتم تقييم الإجابة بعد استلامها داخل الخادم وتحديد النتيجة وإرجاع الشرح التوضيحي المعتمد.

التقييم القبلي والبعدي المقتن:

تجميد نتيجة التقييم القبلي الأولية لمنع التلاعب، ومقارنتها بالتقييم البعدي لقياس نسبة التطور الفعلي بدقة.

الربط التلقائي بمحرك التوصيات:

تسجيل الأخطاء فورياً لتوجيه المستخدم إلى الدروس المعالجة لنقاط ضعفه.

محاكي السيناريوهات التفاعلية والتعلم التجريبي

مزايا المحاكاة التفاعلية: (Experiential Learning)

معايشة واقعية للتهديد:

وضع المتدرب في قلب موقف هجومي فعلي (مثل وصول بريد تظاهر بطلب تحديث بيانات بنكية عاجلة أو رسالة انتحال دعم فني).

تدفق متعدد الخطوات: (Step-by-Step)

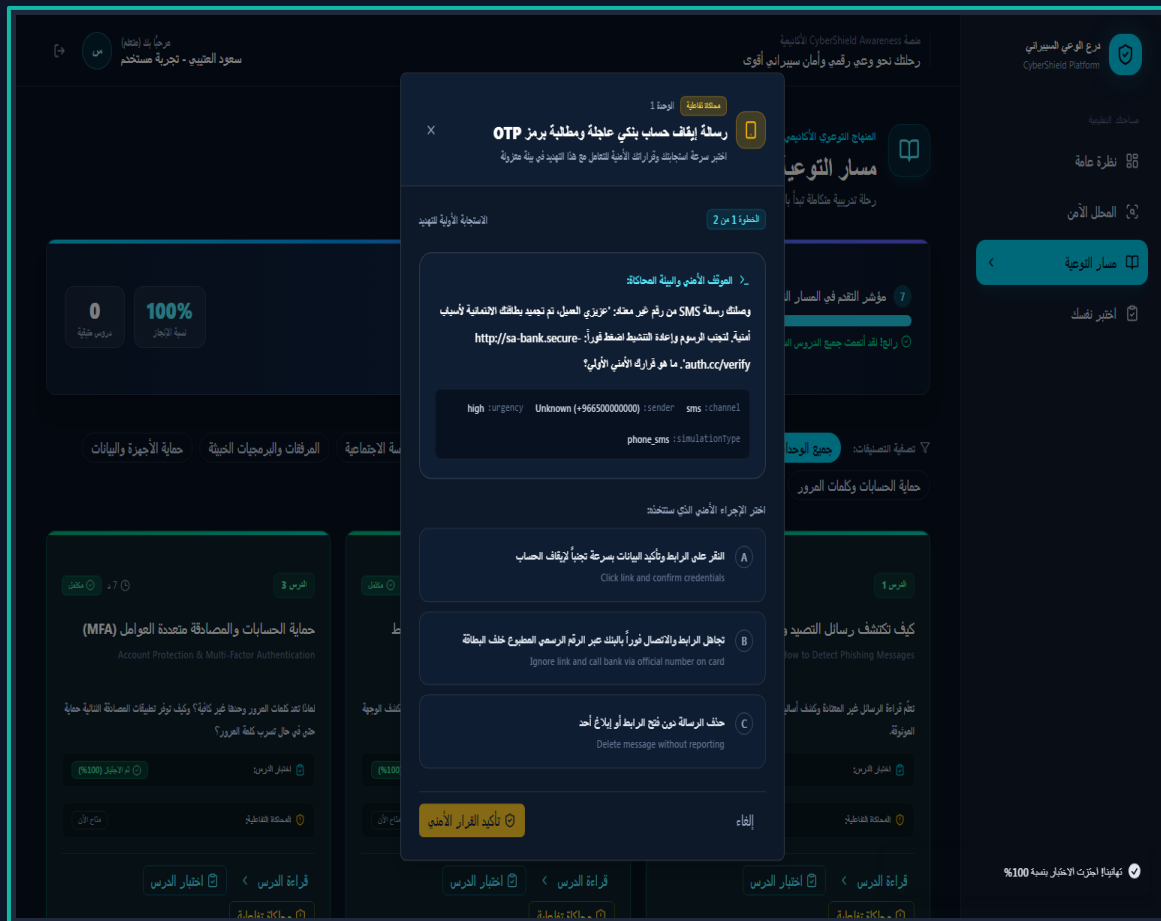
الموقف لا ينتهي بسؤال منفرد، بل تتشعب الأحداث وفق خيار المتدرب لاختبار تبعات قراره.

ملاحظة الأثر الفوري للقرار:

في حال اتخاذ قرار خاطئ، يشاهد المتدرب تداعيات الاختراق في بيئة افتراضية آمنة خالية من المخاطر الحقيقية.

حماية مسار السيناريو:

لا يرسل الخادم خطوات السيناريو أو نتائجه دفعة واحدة، بل يقدم الخطوة الحالية فقط لمنع استباق الحل.



محاكي السيناريوهات التفاعلية واستلام الموقف السيبراني: (3) شكل

المحلل الآمن للروابط والرسائل (Safe Analyzer)

تسجيل الدخول / حساب جديد

مبادرة CyberShield Awareness
رحلتك نحو وعي رقمي وأمان سيبراني أقوى

دع الوعي السيبراني
CyberShield Platform

مساحك الشخصية

نظرة عامة

المحلل الآمن

مسار التوعية

اختبر نفسك

تحليل بدون مخاطرة (Safe Static Analysis)

المحلل الآمن للروابط والرسائل

افحص المؤشرات النصية والتركيبية دون زيارة الرابط أو الاتصال بمصدر خارجي.

تحليل رابط

تحليل رسالة

الرابط التحريبي

مثال: http://secure-verify.bank-update.test/login

تحليل المؤشرات الآن

تأكيد الأمان

التحليل مدعوم وتعليمي عالي الأمان بدون
الوصول المباشر للمصدر المشكوك تحليته

شكل (4): واجهة المحلل الآمن لفحص وتفكيك بنية الروابط المشبوهة

الهندسة الأمنية للمحلل الآمن: (Zero-Contact)

تفكيك بنية النطاق: (Domain Parsing)

استخراج اسم النطاق الأساسي، النطاق الأعلى (TLD)، والنطاقات الفرعية بدقة.

كشف حيل التلاعب البصري: (Punycode)

رصد الحروف البديلة والرموز المتطابقة شكلاً (Homograph Attacks) والروابط المختصرة.

رصد مؤشرات الهندسة الاجتماعية في الرسائل:

اكتشاف عبارات الاستعجال والتهديد وطلبات البيانات البنكية والجوائز الوهمية.

الفحص الاستدلالي المعزول كلياً: (Local Heuristics)

التحليل يتم محلياً بنسبة 100% دون أن يقوم المتصفح أو الخادم بزيارة الرابط الفعلي، مما يوفر حماية مطلقة لبيئة الفحص.

منظومة الأمان وحماية الملكية (Security Architecture & IDOR)

1. حماية الملكية ومنع ثغرات IDOR

التحقق الصارم من معرف المنشئ (ownerId) في كل استعلام، مع حصانة مطلقة للدروس الرسمية السبعة ضد التعديل.

2. التحكم بالوصول (RBAC)

فصل الصلاحيات بدقة بين المتدرب (Student) والمدرس (Instructor) والمدير (Admin) عبر Middleware متخصص.

3. أمن الجلسات (HttpOnly Cookies)

إدارة الجلسات برمز JWT لموقع ومحفوظة في ملفات تعريف ارتباط مشفرة ومحمية من هجمات XSS وسرقة الجلسات.

4. تشفير كلمات المرور (Bcrypt)

تجزئة كلمات المرور باستخدام خوارزمية Bcrypt مع التمليح العشوائي القوي (Salt) لمنع هجمات القواميس والجداول العكسية.

5. سياسة أمان المحتوى الصارمة (CSP)

فرض قيود مشددة على مصادر تشغيل النصوص والخطوط الخارجية لمنع أي حقن برمجي خبيث وحماية المتصفح.

6. كبح القوة الغاشمة (Rate Limiting)

حظر تكرار الطلبات آلياً لمنع محاولات التخمين وهجمات حجب الخدمة على واجهات المصادقة والتقييم.

التحقق البرمجي المعملّي: نجاح 157 اختباراً آلياً بنسبة 100%

```
pwsh - Vitest Automated Test Runner - Platform Validation Suite

> cybcrime-awareness-platform@1.0.0 test
> vitest run

RUN v2.1.9 C:/Users/DELL/Downloads/cybcrime-aware-improved

✓ server/assessment.test.ts (11 tests) 122ms
✓ server/instructor_dashboard.test.ts (11 tests) 147ms
✓ server/admin_dashboard.test.ts (22 tests) 177ms
✓ server/recommendation.test.ts (9 tests) 188ms
✓ server/instructor_quiz.test.ts (10 tests) 343ms
✓ server/phase4_final_journey.test.ts (16 tests) 761ms
✓ server/ratelimit.test.ts (9 tests) 36ms
✓ server/scenario.test.ts (19 tests) 2921ms
✓ server/content.test.ts (9 tests) 211ms
✓ server/quiz.test.ts (7 tests) 521ms
✓ server/quiz_hub.test.ts (7 tests) 911ms
✓ server/fullstack.test.ts (7 tests) 211ms
✓ server/auth.test.ts (8 tests) 1364ms
✓ server/auth.logout.test.ts (1 test) 20ms
✓ server/auth.local.test.ts (11 tests) 3296ms

Test Files 15 passed (15)
Tests 157 passed (157)
Start at 14:21:07 | Duration: 9.44s
```

(نجاحاً 157 Vitest مخرجات تشغيل حزمة الاختبارات الآلية عبر: (5) شكل

إحصائيات حزمة الاختبارات الآلية (15) ملفاً اختبارياً:

- ✓ **اختبارات المصادقة والجلسات: (Auth & Logout)**
20 اختباراً تغطي التشفير والسياسات وتطهير الكوكيز بنجاح. 100%
- ✓ **اختبارات كبح القوة العاشمة: (Rate Limiting)**
9 اختبارات تؤكد حظر تكرار الطلبات والتخمين بنجاح. 100%
- ✓ **اختبارات الملكية ومنع ثغرات: IDOR**
21 اختباراً للمدرسين والدروس الرسمية والأسئلة بنجاح. 100%
- ✓ **اختبارات الاختبارات والسيناريوهات: (Quiz & Scenarios)**
33 اختباراً لحظر تسريب الإجابات وتدفق المراحل بنجاح. 100%
- ✓ **اختبارات التقييم والتوصيات والرحلة الشاملة:**
74 اختباراً للتقييم القبلي والبعدي ولوحة الإدارة والرحلة الكاملة.
- 🎯 **النتيجة الإجمالية الموثقة 157 / 157: نجاحاً بنسبة 100%**
(157 Passed)

التحديات الواقعية أثناء التطوير والحلول الهندسية المطبقة

1. منع ثغرات IDOR مع حماية الدروس الرسمية

التحدي: تمكين المدرس من إنشاء محتواه بحرية مع منع التعدي على دروس زملائه أو حذف الدروس الرسمية المعتمدة.
✓الحل المطبق: ربط الكيانات بـ `ownerId` وإنفاذ التحقق عبر `InstructorProcedure` مع فرض حصانة برمجية صلبة للدروس السبعة.

2. فحص الروابط المشبوهة بعزل تام

التحدي: تحليل النطاقات المشبوهة دون أن يقوم الخادم أو المتصفح بزيارة الرابط الفعلي وتعرض النظام للاختراق.
✓الحل المطبق: بناء خوارزمية استدلالية محلية (Heuristic Domain Parsing) تفكك عناصر الرابط دون أي اتصال شبكي.

3. التوافق مع قيود سياسة أمان المحتوى (CSP)

التحدي: تطبيق CSP المشدد تسبب في حظر تحميل الخطوط والموارد الخارجية في المتصفح.
✓الحل المطبق: هندسة رؤوس أمان المحتوى بدقة عالية وحصر النطاقات المصرحة لخطوط Google دون فتح أي ثغرة.

4. منع كشف خطوات السيناريو مسبقاً

التحدي: احتمالية قيام المتعلم باستباق الحل أو استخراج نتائج السيناريو عبر فحص حزم الشبكة.
✓الحل المطبق: اعتماد معمارية تسليم تدريجي (Step-by-Step Server Flow)؛ فالخادم لا يرسل الخطوة التالية إلا بعد اعتماد السابقة.

الخاتمة، الرؤية المستقبلية وفتح باب المناقشة (Q&A)

🏆 ثمار المشروع والتوصيات المستقبلية:

إثبات تفوق التعلم التجريبي:

أكدت النتائج تفوق المحاكاة التفاعلية في ترسيخ السلوك الدفاعي مقارنة بالتوعية الساكنة.

الجاهزية والامتثال الأمني:

تأكيد مناعة النظام وخلوه من الثغرات باجتياز 157 اختباراً آلياً بنسبة 100%.

دمج الذكاء الاصطناعي مستقبلاً:

توسيع المنصة بنماذج ذكاء اصطناعي تحاكي هجمات التزييف العميق (Deepfake) المتقدمة.

تطبيقات الهواتف المحمولة:

إطلاق تطبيق للهواتف الذكية لزيادة الانتشار وتوفير إشعارات توعوية دورية للمجتمع.

شكراً لحسن استماعكم

خالص الشكر والتقدير للمدربة القديرة:

الأستاذة / عفاف أحمد

ولأعضاء لجنة التقييم الموقرة على وقتهم وملاحظاتهم القيمة

🗨️ نرحب بأسئلتكم واستفساراتكم (Q&A)